

Endnotes

[1]	This booklet uses the terms "institution" and "financial institution" to describe insured banks, thrifts, and credit unions, as well as technology service providers that provide services to such entities.
[2]	Board of Governors of the Federal Reserve System (Federal Reserve Board), Federal Deposit Insurance Corporation (FDIC), National Credit Union Administration (NCUA), Office of the Comptroller of the Currency (OCC), and Office of Thrift Supervision (OTS).
[3]	These include the "Interagency Policy Statement on the Internal Audit Function and Its Outsourcing," March 17, 2003; "Interagency Policy Statement on External Auditing Programs of Banks and Savings Associations," September 22, 1999; and "Interagency Policy Statement on Coordination and Communication Between External Auditors and Examiners," July 23, 1992.
[4]	A federal credit union board of directors is required to establish a "supervisory committee" with oversight responsibility for audit. A supervisory committee consists of not less than three members, nor more than five members, one of whom may be a director other than the compensated officer of the board.
[5]	Sarbanes-Oxley Act of 2002 (Public Law 107-204) puts into place significant new requirements that provide for auditor independence of registered companies that will apply, through FDIC guidelines, (1) to any financial institution that is required under banking laws to have an annual independent audit or (2) to its holding company if the bank satisfies this requirement at the holding company level. All insured depository institutions with \$500 million or more in total assets are required under banking laws to have an annual audit by an independent public accountant. If the institution is a subsidiary of a holding company, it can satisfy this requirement by an independent audit of the holding company. Further, the Federal Reserve Board may apply the auditor independence requirements in the Act to all bank holding companies that are required by the Federal Reserve Board to have an annual audit by an independent public accountant even if no subsidiary institution is subject to the requirements.
[6]	Administrative matters in this context include routine personnel matters such as leave and attendance reporting, expense account management, and other departmental matters such as furniture, equipment and supplies.
[7]	Scoring refers to any consistent means of quantifying and then comparing distinct items based on elements that they have in common. All risk-based systems require some means to rank greater or lesser risk, or risk factors. Consequently, many risk-based systems rely on some means of scoring in their implementation.
[8]	In general, the contract between the institution and the audit provider may or may not be the same as the engagement letter.
[9]	If work papers are in electronic format, contracts often call for the vendor to maintain the software that allows the institution and examiners access to electronic work papers during a specified period of time.

[10] FDICIA Section 112 (12 USC Section 1831m(g)(3)) provides that all auditors are required to make their work papers available to bank examiners. 12 CFR 715.9(c) requires credit unions to obtain a signed audit engagement letter that includes a certification of unconditional access to the complete set of original working papers by credit union examiners.

[11] For example, AICPA's SSAE-16 Type I and Type II, SOC 2 Type I and Type II, SOC 3 (Web Trust). See http://www.aicpa.org/_catalogs/masterpage/Search.aspx?S=soc+1

[12] ISACA, NIST, IAA, & etc.

[13] Shared Assessments Program; see <http://www.sharedassessments.org/>

Appendix A: Examination Procedures

Examination objectives allow the examiner to determine the quality and effectiveness of the audit function related to IT controls. These procedures will disclose the adequacy of audit coverage and to what extent, if any, the examiner may rely upon the procedures performed by the auditors in determining the scope of the IT examination.

- Tier I objectives and procedures relate to the institution's implementation of an effective audit function that may be relied upon to identify and manage risks.
- Tier II objectives and procedures provide additional validation as warranted by risk to verify the effectiveness of the institution's audit function. Tier II questions correspond to the Uniform Rating System for Information Technology (URSIT) rating areas and can be used to determine where the examiner may rely upon audit work in determining the scope of the IT examination for those areas.

TIER I OBJECTIVES AND PROCEDURES

Objective 1: Determine the scope and objectives of the examination of the IT audit function and coordinate with examiners reviewing other programs.

1. Review past reports for outstanding issues, previous problems, or high-risk areas with insufficient coverage related to IT. Consider:

- Regulatory reports of examination;
- Internal and external audit reports, including correspondence/communication between the institution and auditors;
- Regulatory, audit, and security reports from key service providers;
- Audit information and summary packages submitted to the board or its audit committee;
- Audit plans and scopes, including any external audit or internal audit outsourcing engagement letters; and
- Institution's overall risk assessment.

2. Review the most recent IT internal and external audit reports in order to determine:

- Management's role in IT audit activities;

- Any significant changes in business strategy, activities, or technology that could affect the audit function;
- Any material changes in the audit program, scope, schedule, or staffing related to internal and external audit activities; and
- Any other internal or external factors that could affect the audit function.

3. Review management's response to issues raised since the last examination. Consider:

- Adequacy and timing of corrective action;
- Resolution of root causes rather than just specific issues; and
- Existence of any outstanding issues.

4. Assess the quality of the IT audit function. Consider:

- Audit staff and IT qualifications, and
- IT audit policies, procedures, and processes.

Using the results from the preceding procedures and discussions with the EIC, select from the following examination procedures those necessary to meet the examination objectives. Note: examinations do not necessarily require all steps.

Objective 2: Determine the quality of the oversight and support of the IT audit function provided by the board of directors and senior management.

1. Review board resolutions and audit charter to determine the authority and mission of the IT audit function.
2. Review and summarize the minutes of the board or audit committee for member attendance and supervision of IT audit activities.
3. Determine if the board reviews and approves IT policies, procedures, and processes.
4. Determine if the board approves audit plans and schedules, reviews actual performance of plans and schedules, and approves major deviations to the plan.
5. Determine if the content and timeliness of audit reports and issues presented to and reviewed by the board of directors or audit committee are appropriate.

6. Determine whether the internal audit manager and the external auditor report directly to the board or to an appropriate audit committee and, if warranted, has the opportunity to escalate issues to the board both through the normal audit committee process and through the more direct communication with outside directors.

Objective 3: Determine the credentials of the board of directors or its audit committee related to their ability to oversee the IT audit function.

1. Review credentials of board members related to abilities to provide adequate oversight. Examiners should:

- Determine if directors responsible for audit oversight have appropriate level of experience and knowledge of IT and related risks; and
- If directors are not qualified in relation to IT risks, determine if they bring in outside independent consultants to support their oversight efforts through education and training.

2. Determine if the composition of the audit committee is appropriate considering entity type and complies with all applicable laws and regulations. Note - If the institution is a publicly traded company, this is a requirement of Sarbanes-Oxley. Additionally, this is a requirement of FDICIA for institutions with total assets greater than \$500 million.

Objective 4: Determine the qualifications of the IT audit staff and its continued development through training and continuing education.

1. Determine if the IT audit staff is adequate in number and is technically competent to accomplish its mission. Consider:

- IT audit personnel qualifications and compare them to the job descriptions;
- Whether staff competency is commensurate with the technology in use at the institution; and
- Trends in IT audit staffing to identify any negative trends in the adequacy of staffing.

Objective 5: Determine the level of audit independence.

1. Determine if the reporting process for the IT audit is independent in fact and in appearance by reviewing the degree of control persons outside of the audit function have on what is reported to the board or audit committee.

2. Review the internal audit organization structure for independence and clarity of the reporting process. Determine whether independence is compromised by:

- The internal audit manager reporting functionally to a senior management official (i.e., CFO, controller, or similar officer);
- The internal audit manager's compensation and performance appraisal being done by someone other than the board or audit committee; or
- Auditors responsible for operating a system of internal controls or actually performing operational duties or activities.

Note that it is recommended that the internal audit manager report directly to the audit committee functionally on audit issues and may also report to senior management for administrative matters.

Objective 6: Determine the existence of timely and formal follow-up and reporting on management's resolution of identified IT problems or weaknesses.

1. Determine whether management takes appropriate and timely action on IT audit findings and recommendations and whether audit or management reports the action to the board of directors or its audit committee. Also, determine if IT audit reviews or tests management's statements regarding the resolution of findings and recommendations.

2. Obtain a list of outstanding IT audit items and compare the list with audit reports to ascertain completeness.

3. Determine whether management sufficiently corrects the root causes of all significant deficiencies noted in the audit reports and, if not, determine why corrective action is not sufficient.

Objective 7: Determine the adequacy of the overall audit plan in providing appropriate coverage of IT risks.

1. Interview management and review examination information to identify changes to the institution's risk profile that would affect the scope of the audit function. Consider:

- Institution's risk assessment,

- Products or services delivered to either internal or external users,
- Loss or addition of key personnel, and
- Technology service providers and software vendor listings.

2. Review the institution's IT audit standards manual and/or IT-related sections of the institution's general audit manual. Assess the adequacy of policies, practices, and procedures covering the format and content of reports, distribution of reports, resolution of audit findings, format and contents of work papers, and security over audit materials.

Objective 8: Determine the adequacy of audit's risk analysis methodology in prioritizing the allocation of audit resources and formulating the IT audit schedule.

1. Evaluate audit planning and scheduling criteria, including risk analysis, for selection, scope, and frequency of audits. Determine if:

- The audit universe is well defined; and
- Audit schedules and audit cycles support the entire audit universe, are reasonable, and are being met.

2. Determine whether the institution has appropriate standards and processes for risk-based auditing and internal risk assessments that:

- Include risk profiles identifying and defining the risk and control factors to assess and the risk management and control structures for each IT product, service, or function; and
- Describe the process for assessing and documenting risk and control factors and its application in the formulation of audit plans, resource allocations, audit scopes, and audit cycle frequency

Objective 9: Determine the adequacy of the scope, frequency, accuracy, and timeliness of IT-related audit reports.

1. Review a sample of the institution's IT-related audit reports and work papers for specific audit ratings, completeness, and compliance with board and audit committee-approved standards.

2. Analyze the internal auditor's evaluation of IT controls and compare it with any evaluations done by examiners.

3. Evaluate the scope of the auditor's work as it relates to the institution's size, the nature and extent of its activities, and the institution's risk profile.

4. Determine if the work papers disclose that specific program steps, calculations, or other evidence support the procedures and conclusions set forth in the reports.

5. Determine through review of the audit reports and work papers if the auditors accurately identify and consistently report weaknesses and risks.

6. Determine if audit report content is:

- Timely
- Constructive
- Accurate
- Complete

Objective 10: Determine the extent of audit's participation in application development, acquisition, and testing, as part of the organization's process to ensure the effectiveness of internal controls.

1. Discuss with audit management and review audit policies related to audit participation in application development, acquisition, and testing.

2. Review the methodology management employs to notify the IT auditor of proposed new applications, major changes to existing applications, modifications/additions to the operating system, and other changes to the data processing environment.

3. Determine the adequacy and independence of audit in:

- Participating in the systems development life cycle;

- Reviewing major changes to applications or the operating system;
- Updating audit procedures, software, and documentation for changes in the systems or environment; and
- Recommending changes to new proposals or to existing applications and systems to address audit and control issues.

Objective 11: If the IT internal audit function, or any portion of it, is outsourced to external vendors, determine its effectiveness and whether the institution can appropriately rely on it.

1. Obtain copies of:

- Outsourcing contracts and engagement letters,
- Outsourced internal audit reports, and
- Policies on outsourced audit.

2. Review the outsourcing contracts/engagement letters and policies to determine whether they adequately:

- Define the expectations and responsibilities under the contract for both parties.
- Set the scope, frequency, and cost of work to be performed by the vendor.
- Set responsibilities for providing and receiving information, such as the manner and frequency of reporting to senior management and directors about the status of contract work.
- Establish the protocol for changing the terms of the service contract, especially for expansion of audit work if significant issues are found, and stipulations for default and termination of the contract.
- State that internal audit reports are the property of the institution, that the institution will be provided with any copies of the related work papers it deems necessary, and that employees authorized by the institution will have reasonable and timely access to the work papers prepared by the outsourcing vendor.
- State that any information pertaining to the institution must be kept confidential.
- Specify the locations of internal audit reports and the related work papers.
- Specify the period of time that vendors must maintain the work papers. If work papers are in electronic format, contracts often call for vendors to maintain

proprietary software that allows the institution and examiners access to electronic work papers during a specified period.

- State that outsourced internal audit services provided by the vendor are subject to regulatory review and that examiners will be granted full and timely access to the internal audit reports and related work papers and other materials prepared by the outsourcing vendor.
- Prescribe a process (arbitration, mediation, or other means) for resolving problems and for determining who bears the cost of consequential damages arising from errors, omissions and negligence.
- State that outsourcing vendors will not perform management functions, make management decisions, or act or appear to act in a capacity equivalent to that of a member of institution management or an employee and, if applicable, they are subject to professional or regulatory independence guidance.

3. Consider arranging a meeting with the IT audit vendor to discuss the vendor's outsourcing internal audit program and determine the auditor's qualifications.

4. Determine whether the outsourcing arrangement maintains or improves the quality of the internal audit function and the institution's internal controls. The examiner should:

- Review the performance and contractual criteria for the audit vendor and any internal evaluations of the audit vendor;
- Review outsourced internal audit reports and a sample of audit work papers. Determine whether they are adequate and prepared in accordance with the audit program and the outsourcing agreement;
- Determine whether work papers disclose that specific program steps, calculations, or other evidence support the procedures and conclusions set forth in the outsourced reports; and
- Determine whether the scope of the outsourced internal audit procedures is adequate.

5. Determine whether key employees of the institution and the audit vendor clearly understand the lines of communication and how any internal control problems or other matters noted by the audit vendor during internal audits are to be addressed.

6. Determine whether management or the audit vendor revises the scope of outsourced audit work appropriately when the institution's environment, activities, risk exposures, or systems change significantly.